

INCIDENT RESPONSE PLAYBOOK

Malware Infection — Enhanced Edition

FRAMEWORK	MITRE ATT&CK v14 NIST SP 800-61r2
VERSION	v2.0 — Enhanced Release
AUTHOR	BlueShield Team
DATE	June 2026
INCIDENT TYPE	Malware Infection

★ ENHANCED EDITION v2.0

Includes: Sub-playbooks | Triage scripts | Chain of custody
Comms templates | Legal annex | Real-world labs

TABLE OF CONTENTS

Section	Title	Page
1	Playbook Overview	3
2	Roles & Responsibilities	4
3	Incident Response Phases	5
4	Malware-Type Sub-Playbooks ★ NEW	10
5	Analyst Decision Tree	14
6	Triage Command Bank ★ NEW	15
7	MITRE ATT&CK Mapping (Extended) ★ ENHANCED	17
8	MITRE ATT&CK Coverage Heatmap	20
9	Malware Type Quick-Reference	21
10	IOC Collection & Chain of Custody ★ ENHANCED	22
11	Escalation Matrix ★ ENHANCED	23
12	Stakeholder Communication Templates ★ NEW	24
13	Legal & Regulatory Annex ★ NEW	25
14	Tools Reference	26
15	Post-Incident Metrics & KPIs ★ NEW	27
16	References & Further Reading	28
17	Appendix — Incident Report Template	29

1 PLAYBOOK OVERVIEW

1.1 Purpose

This playbook provides a structured, step-by-step guide for detecting, containing, eradicating, and recovering from Malware Infection incidents. It is designed for SOC Analysts, Incident Responders, and IT Security teams. This enhanced edition (v2.0) adds malware-type sub-playbooks, triage command scripts, chain-of-custody procedures, stakeholder communication templates, and a legal/regulatory annex.

1.2 Malware Definition

Malware is malicious software designed to harm, disrupt, or gain unauthorised access to computers, servers, or networks. It includes viruses, worms, trojans, ransomware, spyware, rootkits, botnets, keyloggers, cryptominers, and other malicious code.

1.3 Scope

- Endpoints: Workstations, Servers, Laptops
- Network segments visible to SIEM
- Malware types: Trojans, Worms, Spyware, Ransomware-droppers, RATs, Backdoors, Fileless, Rootkits
- Excludes: Full Ransomware encryption events (see Ransomware Playbook)

1.4 Severity Classification

Severity	Criteria	Response SLA	SLA Breach Action	Escalation
CRITICAL	Active C2, lateral movement, data exfiltration	Immediate (<15 min)	Auto-escalate to CISO + War Room at 15 min	L3 + Management
HIGH	Confirmed infection, no spread detected	<1 hour	Escalate to L3 at 60-min mark; notify SOC manager	L2/L3
MEDIUM	Suspicious indicators, unconfirmed infection	<4 hours	Escalate to L2 at 4-hr mark; log SLA miss in ticket	L2
LOW	Potentially unwanted software (PUP)	<24 hours	Log missed SLA; weekly review	L1

★ **Enhanced (v2.0):** SLA breach actions now defined for each severity level. SLA timers must be tracked in the ticketing system and auto-alert the on-call manager if breached.

2 ROLES & RESPONSIBILITIES

Role	Primary Responsibility	Authority Level
SOC Analyst (L1)	First responder: triage alerts, initial investigation, log collection, IOC gathering	Observe / Collect
SOC Lead / L2 Analyst	Deep investigation, malware analysis, threat correlation, MITRE ATT&CK; mapping, sub-playbook execution	Investigate / Contain
Incident Commander (L3)	Oversees response, authorises containment actions, manages escalation, coordinates war room	Authorise / Command
IT / Sysadmin Team	Executes isolation commands, VLAN changes, patch deployment, system reimaging, NAC quarantine	Execute
Threat Intelligence	Identifies malware family, validates IOCs, correlates TTPs with threat feeds, supports MITRE mapping	Advise
Legal / Compliance	Advises on regulatory notification timelines (GDPR/HIPAA/PCI), legal hold, law enforcement liaison	Advise / Approve
Management / CISO	Business decisions, external communications, regulatory reporting approval, insurance notification	Decide / Approve
PR / Comms	Manages media/customer-facing communications; coordinates approved statements through templates in §12	Publish (approved)

★ **Enhanced (v2.0):** Legal/Compliance and PR/Comms roles added. During Critical incidents, all roles convene in a War Room (virtual or physical) chaired by the Incident Commander.

3 INCIDENT RESPONSE PHASES

This playbook follows the NIST SP 800-61r2 Incident Response Lifecycle adapted for Malware Infection scenarios.

Phase 1 — Preparation

Objective: Establish the people, processes, and technologies required to effectively detect, respond to, and recover from malware incidents.

Security Controls & Monitoring

- Ensure Anti-Malware and EDR solutions are deployed, updated, and monitored
- Enable centralised logging and SIEM monitoring across critical systems
- Configure detection rules for malware execution, persistence, C2 activity, lateral movement, and data exfiltration
- Maintain secure, air-gapped or immutable backups and an up-to-date asset inventory
- Deploy Sysmon with SwiftOnSecurity config on all Windows endpoints

IR Readiness

- Maintain and regularly review IR procedures and escalation paths
- Define roles, responsibilities, and communication channels (War Room bridge)
- Ensure access to forensic tools and out-of-band communication
- Establish evidence preservation and chain-of-custody procedures (see §10)
- Pre-position triage scripts on IR jump boxes (see §6)

Key Deliverables:

- Active Security Monitoring
- Updated IR Procedures
- Defined Escalation Process
- Current Threat Intelligence Sources
- Trained Personnel
- Tested Backup and Recovery Capabilities
- Pre-staged Forensic Jump Box
- Verified Chain-of-Custody Forms

Phase 2 — Detection

Objective: Detect, validate, and classify malware-related incidents; determine scope and impact; initiate the appropriate IR process.

Detection Activities:

- Monitor security alerts from SIEM, EDR, Anti-Malware, IDS/IPS, and user reports
- Validate alerts to determine whether malicious activity is present (use Decision Tree §5)
- Create or update an incident ticket; document all findings with timestamps
- Classify incident severity based on affected assets, business impact, and infection scope
- Escalate confirmed or suspected malware incidents per the IR Plan

Initial Investigation:

- Identify affected hosts, users, accounts, and applications
- Determine the malware infection vector (email, web download, removable media, exploit, RDP brute-force)
- Assess the scope of compromise and identify signs of propagation
- Review endpoint, network, authentication, and security logs
- Collect and preserve evidence (file hashes, malicious files, process info, network connections, logs)
- Correlate findings with threat intelligence sources and known IOCs

★ Escalation Criteria — escalate IMMEDIATELY if any of the following are identified:

Trigger	Action	Severity
Active malware spreading across multiple systems	Isolate network segment; mobilise L3	CRITICAL
Confirmed Command-and-Control (C2) activity	Block at firewall; escalate to L3	CRITICAL

Trigger	Action	Severity
Privileged account compromise	Disable account; force password reset	CRITICAL
Critical server or business system affected	Notify L2 + IT Manager immediately	HIGH
Evidence of data theft or exfiltration	Preserve evidence; notify CISO + Legal	CRITICAL
Ransomware dropper activity detected	Do NOT wait — isolate immediately	CRITICAL

Phase 3 — Analysis

Objective: Determine scope, impact, and root cause; identify affected assets; develop an effective containment and remediation strategy.

Malware Analysis:

- Identify the malware family, type, and capabilities using threat intel platforms and sandbox analysis
- Validate IOCs: file hashes, IP addresses, domains, URLs, registry artifacts
- Determine malware persistence mechanisms and execution methods
- Reverse engineer malware in secure sandbox (Any.run, Hybrid Analysis) to understand C2 protocol

Scope Assessment:

- Establish a timeline of malicious activity and key events
- Identify affected systems, users, accounts, and applications
- Assess whether the malware has spread to additional hosts (check authentication logs for lateral movement)
- Determine the initial infection vector and full attack path

Impact Analysis — assess evidence of:

Category	Indicators
Persistence	Registry run keys, scheduled tasks, new services, WMI subscriptions
Privilege Escalation	New local admin accounts, Token manipulation, UAC bypass
Lateral Movement	Pass-the-Hash, RDP sessions, SMB connections to other hosts
C2 Communication	Beaconing patterns, DNS tunnelling, encrypted outbound channels
Data Exfiltration	Large outbound transfers, cloud upload activity, USB writes

Phase 4 — Remediation (Containment, Eradication & Recovery)

Objective: Contain the malware infection, eradicate malicious artifacts, and safely restore affected systems and services.

Containment:

- Isolate infected or suspected systems from the network — use EDR isolation, VLAN quarantine, or NAC quarantine profile (do NOT simply unplug if forensics are needed)
- Block malicious IPs, domains, URLs, and C2 communications at perimeter firewall and DNS sinkhole
- Disable or restrict compromised accounts; enforce MFA on all privileged accounts
- Preserve critical evidence BEFORE making changes (RAM dump, disk image, log export)
- Communicate containment status to relevant stakeholders
- ★ **Verify backup integrity: confirm backup predates infection before relying on restore**

Eradication:

- Remove malware using approved EDR tools and remediation procedures
- Eliminate all persistence mechanisms: registry keys, scheduled tasks, services, WMI subscriptions, startup folders
- Reimage systems when integrity cannot be verified (rootkit or fileless infection)
- Apply security patches and remediate exploited vulnerabilities
- Reset ALL credentials associated with affected systems, users, and service accounts
- Validate that all IOCs have been removed; run a full AV + EDR scan post-removal

Recovery:

- Validate backup integrity before restore: scan backup image in isolated sandbox, confirm backup date predates infection timeline
- Restore affected systems and data from verified clean backups
- Reconnect remediated systems to production environment in stages
- Perform full malware and security validation scans before returning systems to service
- Monitor systems closely for 72 hours for signs of reinfection or residual C2
- Confirm normal business operations have been restored with business owners

Phase 5 — Post-Incident Activities

Objective: Document the incident, identify lessons learned, improve security controls, and implement corrective actions.

Incident Reporting:

- Prepare a final incident report detailing: timeline, root cause, scope, impact, containment/eradication actions, recovery, recommendations
- Submit the report to relevant stakeholders and management within 5 business days
- File regulatory notifications as required (GDPR 72-hr clock, HIPAA, PCI DSS — see §13)

Lessons Learned & Continuous Improvement:

- Conduct a post-incident review meeting within 5 business days with all relevant teams
- Identify gaps in people, processes, and technology; track all improvement actions in a register
- Update detection rules, response procedures, and playbooks based on findings
- Update KPI dashboard (see §15) with incident metrics: MTTD, MTTR, SLA compliance

Key Deliverables:

- Final Incident Report
- Root Cause Analysis
- Lessons Learned Report
- Updated Detection Rules
- Updated Playbook & Procedures
- Corrective Action Plan
- KPI / Metrics Update

4 MALWARE-TYPE SUB-PLAYBOOKS

★ ENHANCED

When a malware type is confirmed during Analysis (§3), branch to the appropriate sub-playbook below. Execute type-specific steps IN ADDITION TO the main phase procedures in §3.

4.x Fileless Malware

Examples: PowerShell Empire, Cobalt Strike, LOLBin abuse

Step	Action
IMMEDIATE	Do NOT reboot — all evidence lives in memory. RAM dump is mandatory before any other action.
Capture	Run Volatility 3 against RAM dump: netscan, pslist, malfind, dlllist, cmdline. Look for injected shellcode in explorer.exe, svchost.exe, lsass.exe.
Detection	Review PowerShell ScriptBlock logs (Event ID 4104), AMSI events, WMI EventFilter/Consumer subscriptions, encoded command strings.
Containment	EDR isolate host. Disable PowerShell execution policy via GPO if spread suspected. Block C2 IPs at firewall.
Eradication	Remove WMI subscriptions (Get-WMIObject, Remove-WMIObject). Clear scheduled tasks. Remove rogue registry run keys. Flush PowerShell history.
Recovery	Reimage if rootkit component suspected. If clean, restore from pre-infection backup. Harden: constrained language mode, AMSI enabled, ScriptBlock logging mandatory.

4.x Rootkit

Examples: ZeroAccess, Necurs, bootkit infections

Step	Action
IMMEDIATE	Do NOT trust ANY output from the compromised OS — rootkit may intercept API calls and hide processes, files, and network connections.
Offline Analysis	Boot from trusted forensic live USB (SANS SIFT, Tsurugi). Mount compromised disk read-only using write-blocker hardware.
Detection	Check MBR/VBR integrity with bootkit scanners. Compare running process list (Volatility pslist) vs psscan to find hidden processes. Scan for DKOM (Direct Kernel Object Manipulation).
Containment	Network isolation immediately. Do NOT run AV from within the infected OS — result is unreliable. Disconnect from domain if domain-joined.
Eradication	Full OS reinstall is almost always required. Reimage from known-good image. Restore MBR using Windows Recovery: bootrec /fixmbr /fixboot. Flash firmware if rootkit suspected at firmware level.
Recovery	Fresh OS install from verified ISO. Restore data only (not applications) from pre-infection backup. Re-join to domain only after CISO approval.

4.x RAT (Remote Access Trojan)

Examples: DarkComet, NjRAT, AsyncRAT, QuasarRAT

Step	Action
IMMEDIATE	Assume the attacker has full visibility of the compromised host. Do not type credentials or view sensitive data on the infected machine.
Detection	Identify persistent outbound connections (TCPView, netstat). Look for webcam/mic activation events. Check for remote shell child processes spawned from explorer.exe or Office apps.
Containment	EDR isolate host. Block C2 IP/domain at firewall AND DNS. Disable affected user account. Identify all hosts that communicated with same C2 — check firewall logs.
Forensics	Full disk image for forensics. Extract C2 config from memory or binary (look for hardcoded IP/domain, port, campaign ID). Check for keylogger artefacts: temp files, clipboard captures.
Eradication	Remove persistence (registry, scheduled task, startup). Terminate and delete RAT binary. Reset ALL credentials the user typed while infected. Notify affected users.
Recovery	Rebuild host. Force password reset for all accounts logged in during infection window. Review all data accessible from that host for potential exfiltration.

4.x Worm

Examples: WannaCry (pre-ransom stage), Conficker, Emotet spreading phase

Step	Action
IMMEDIATE	Speed is critical — worms self-replicate. Identify spread vector (SMB, RDP, email, USB) within first 10 minutes.
Containment	Isolate affected VLAN/subnet immediately. Disable SMB (ports 445/139) at firewall if SMB worm. Block USB via GPO. Identify Patient Zero using authentication and network logs.
Scope	Query SIEM for all hosts that connected to Patient Zero in the past 24-48 hours. Scan all potentially exposed hosts. Create an infection map.
Eradication	Patch the exploited vulnerability across ALL hosts before reconnecting to network (e.g., MS17-010 for EternalBlue, CVE-specific patches). Remove worm binary and persistence from all infected hosts.
Recovery	Reconnect hosts only after patch verification. Bring up in isolated VLAN first; monitor 24 hours before full production reconnect.
Prevention	Review network segmentation. Implement host-based firewall rules to block lateral movement. Enforce patch management SLA: Critical patches within 24 hours.

5 ANALYST DECISION TREE

Use this decision tree when an alert fires. Follow each question top-to-bottom to determine the correct response action.

#	Question / Condition	YES → Action	NO → Action
1	Is the alert from a known-good (whitelisted) source?	Close as False Positive. Document reason in ticket.	Proceed to Q2
2	Is there a matching IOC (hash/IP/domain) in Threat Intel feeds?	Escalate to L2. Open High severity ticket.	Proceed to Q3
3	Is there evidence of process injection or unusual parent-child process?	Confirm infection. EDR-isolate host immediately.	Proceed to Q4
4	Is there outbound network traffic to suspicious IPs/domains?	Confirm C2 activity. Block at firewall. Escalate to Critical.	Proceed to Q5
5	Are there persistence mechanisms (registry/scheduled tasks/services/WMI)?	Confirmed persistent infection. Begin Eradication phase. Branch to §4 sub-playbook.	Proceed to Q6
6	Is there evidence of lateral movement (logons to other hosts, Pass-the-Hash)?	Escalate to Critical. Isolate network segment. Notify L3.	Assign Medium. Deep investigation required.
7	Is there evidence of data exfiltration (large outbound transfers, cloud uploads)?	Escalate to Critical. Preserve evidence. Notify CISO + Legal. Activate §12 comms template.	Proceed with standard Eradication + Recovery.
8	★ Is the malware fileless (no files on disk, lives in memory/registry)?	Execute Fileless sub-playbook (§4). RAM capture mandatory.	Continue standard eradication.

Decision Tree — Response Level Summary

Condition Met	Severity	Owner	SLA	SLA Breach Action
IOC match + C2 + Lateral Movement	CRITICAL	L3 + Management	Immediate	Auto war-room at 15 min
IOC match + Persistence (no C2)	HIGH	L2/L3	<1 hour	Escalate to L3 at 60 min
Suspicious indicators, no IOC match	MEDIUM	L2	<4 hours	Escalate to L2 at 4 hr
False positive confirmed	INFO	L1	Document only	Weekly FP review

6 TRIAGE COMMAND BANK

★ ENHANCED

Ready-to-run commands for Windows and Linux. Execute from an IR jump box or remote EDR console. All commands are read-only / evidence-safe unless marked [CONTAINMENT].

Windows — Process & Memory Triage

Purpose	Command
List all running processes with full paths	<code>Get-Process Select-Object Name,Id,Path,Company Sort-Object Name Format-Table -Auto</code>
Find processes with no path (fileless / injection indicator)	<code>Get-Process Where-Object {\$_.Path -eq \$null} Select-Object Name,Id,CPU</code>
Dump process tree (parent-child)	<code>Get-WmiObject Win32_Process Select-Object ProcessId,ParentProcessId,Name,CommandLine Sort-Object ParentProcessId Format-Table</code>
List loaded DLLs for a process (replace PID)	<code>Get-Process -Id Select-Object -ExpandProperty Modules Select-Object FileName</code>
Extract hash of a suspicious file	<code>Get-FileHash -Path "C:\path\to\file.exe" -Algorithm SHA256</code>

Windows — Network Triage

Purpose	Command
Active network connections with owning process	<code>netstat -anob findstr ESTABLISHED</code>
DNS cache (look for C2 domains)	<code>Get-DnsClientCache Select-Object Entry,RecordName,Data Format-Table</code>
Recent outbound connections via PowerShell	<code>Get-NetTCPConnection Where-Object {\$_.State -eq "Established"} Select-Object LocalAddress,LocalPort,RemoteAddress,RemotePort,OwningProcess</code>
[CONTAINMENT] Block IP at host firewall	<code>netsh advfirewall firewall add rule name="IR-Block-C2" dir=out action=block remoteip=</code>

Windows — Persistence Triage

Purpose	Command
Check all autorun registry keys	<code>Get-ItemProperty HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run Get-ItemProperty HKCU:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run</code>
List all scheduled tasks (look for non-standard locations)	<code>Get-ScheduledTask Where-Object {\$_.TaskPath -notlike "\Microsoft*"} Select-Object TaskName,TaskPath,State</code>
List non-Microsoft services	<code>Get-Service Where-Object {\$_.StartType -ne "Disabled"} Select-Object DisplayName,Status,StartType</code>
Check WMI persistent subscriptions	<code>Get-WmiObject -Namespace root/subscription -Class __EventFilter Get-WmiObject -Namespace root/subscription -Class __EventConsumer</code>
List recently created accounts	<code>Get-LocalUser Where-Object {\$_.LastLogon -gt (Get-Date).AddDays(-7)} Select-Object Name,Enabled,LastLogon</code>

Windows — Log & Evidence Collection

Purpose	Command
Export Security event log (authentication events)	<code>wevtutil epl Security C:\IR\Security_\$(hostname)_\$(Get-Date -f yyyyMMdd).evtx</code>
Export Sysmon log	<code>wevtutil epl "Microsoft-Windows-Sysmon/Operational" C:\IR\Sysmon_\$(hostname).evtx</code>

Purpose	Command
Search for Event ID 4688 (process creation) in last 24hr	<code>Get-WinEvent -FilterHashtable @{{LogName="Security";Id=4688;StartTime=(Get-Date).AddHours(-24)}} Select-Object TimeCreated,Message</code>
[EVIDENCE] Capture RAM with WinPmem	<code>.\winpmem.exe --output C:\IR\ram_\$(hostname)_\$(Get-Date -f yyyyMMdd_HH:mm).raw</code>
Hash all collected evidence files	<code>Get-ChildItem C:\IR\ Get-FileHash -Algorithm SHA256 Export-Csv C:\IR\evidence_hashes.csv</code>

Linux — Triage Commands

Purpose	Command
List all processes with full command lines	<code>ps auxf</code>
Active network connections with PID	<code>ss -tulnp # or: netstat -tulnp</code>
Find recently modified files (last 24hr)	<code>find / -mtime -1 -type f -not -path "/proc/*" -not -path "/sys/*" 2>/dev/null</code>
Check crontabs for all users	<code>for user in \$(cut -f1 -d: /etc/passwd); do crontab -u \$user -l 2>/dev/null && echo "--- \$user ---"; done</code>
[EVIDENCE] Memory dump with LIME	<code>insmod lime.ko "path=/mnt/ir/ram_\$(hostname).lime format=lime"</code>
Hash a suspicious binary	<code>sha256sum /path/to/suspicious/binary</code>

★ **Note:** All evidence files must be hashed immediately after collection and logged in the Chain of Custody form (see §10). Commands marked [CONTAINMENT] modify system state — document timestamp and authorisation before executing.

7 MITRE ATT&CK MAPPING (EXTENDED)

★ ENHANCED

The following tables map Malware Infection behaviours to the MITRE ATT&CK; Enterprise framework (v14). This edition adds Lateral Movement, Discovery, and Exfiltration tactics previously missing from v1.0.

7.1 Initial Access

ID	Technique	Description	Detection in SIEM
T1566.001	Spearphishing Attachment	Malware via malicious email attachment (macro-enabled Office, PDF exploit)	Email gateway alerts, Office spawning cmd.exe/powershell.exe
T1189	Drive-by Compromise	User visits compromised website; browser exploit delivers payload	Unusual browser child processes, new files in %TEMP%/ %APPDATA%
T1078	Valid Accounts	Attacker uses stolen credentials to authenticate and deploy malware	Logins from unusual geo/time, auth failures then success
T1190	Exploit Public-Facing App	Malware via exploitation of unpatched internet-facing application	IDS/IPS alerts, unusual app behaviour, error spikes

7.2 Execution

ID	Technique	Description	Detection in SIEM
T1059.001	PowerShell	Malware uses PowerShell to download/execute payloads, often encoded	PowerShell encoded commands, ScriptBlock logging, execution policy bypass
T1059.003	Windows Command Shell	cmd.exe used to run malicious scripts, copy payloads, spawn processes	cmd.exe spawned by Office/Browser, suspicious command strings
T1047	WMI	WMI used to execute code and maintain persistence via event subscriptions	WMI activity logs, new EventFilter/EventConsumer subscriptions
T1204.002	User Execution: Malicious File	User double-clicks malicious attachment, directly executing malware	New process from Downloads/Temp, email attachment opens

7.3 Persistence

ID	Technique	Description	Detection in SIEM
T1547.001	Registry Run Keys	Malware adds itself to HKLM/HKCU Run keys or Startup folder	Sysmon Event 13 (registry mod), new Run key entries from non-standard paths
T1053.005	Scheduled Task	Malware creates scheduled tasks to re-execute at intervals	Sysmon Event 1 (schtasks.exe), new tasks in non-standard locations
T1543.003	Create/Modify System Process	Malware installs as Windows Service to run with system privileges	New service events (Event ID 7045), services from unusual paths
T1546.003	WMI Event Subscription	Malware uses WMI subscriptions for fileless persistence	WMI subscriptions: __EventFilter, CommandLineEventConsumer

7.4 Defense Evasion

ID	Technique	Description	Detection in SIEM
T1036	Masquerading	Malware names itself after legitimate processes (svchost.exe, lsass.exe)	Process running from non-standard path, parent-child anomalies
T1027	Obfuscated Files	Payloads encoded in Base64/XOR or packed to evade AV signatures	High entropy file writes, encoded PowerShell, AMSI bypass attempts
T1562.001	Disable Security Tools	Malware disables Defender, Firewall, event logging to hinder detection	Security service stopped, Event ID 1102 (log cleared), audit policy changes
T1055	Process Injection	Malware injects code into legitimate processes (explorer.exe, lsass.exe)	Sysmon Event 8 (CreateRemoteThread), unusual memory writes

7.5 Command & Control

ID	Technique	Description	Detection in SIEM
T1071.001	Application Layer: Web	Malware uses HTTP/HTTPS to blend C2 with normal web traffic	Beaconing patterns, HTTP to non-categorised domains, new DNS queries
T1071.004	DNS Tunneling	Malware encodes data in DNS queries/responses	High-volume DNS queries, unusually long query strings, uncommon TLDs
T1573	Encrypted Channel	Malware uses encrypted communication to hide C2 traffic	Certificate anomalies (self-signed/expired), unexpected encrypted patterns

7.6 Lateral Movement ★ NEW

★ NEW SECTION

ID	Technique	Description	Detection in SIEM
T1021.001	Remote Services: RDP	Attacker uses RDP to move laterally to other hosts	Event ID 4624 (Type 10 logon), unusual RDP connections between workstations
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral movement via IPC\$, ADMIN\$, C\$ shares	Sysmon Event 3 (network connection) to port 445, PsExec artefacts
T1550.002	Pass the Hash	Attacker uses NTLM hash to authenticate without plaintext password	Event ID 4624 (Type 3) with no corresponding Kerberos event, LSASS access
T1570	Lateral Tool Transfer	Attacker copies tools/malware to other hosts via SMB or RDP clipboard	File creation in ADMIN\$ share, unusual SMB writes from non-server hosts

7.7 Discovery ★ NEW

★ NEW SECTION

ID	Technique	Description	Detection in SIEM
T1057	Process Discovery	Malware enumerates running processes to identify AV/EDR to evade	Unusual calls to CreateToolhelp32Snapshot, high-frequency process enumeration
T1083	File and Directory Discovery	Malware searches for sensitive files (credentials, configs, databases)	Recursive dir/ls commands, access to sensitive paths (/etc/shadow, SAM)
T1016	System Network Configuration Discovery	Attacker maps network: ipconfig, arp, route, nslookup	Burst of network enumeration commands from single host
T1087	Account Discovery	Attacker enumerates local and domain accounts	net user, net group, Get-LocalUser commands; LDAP enumeration

7.8 Exfiltration ★ NEW

★ NEW SECTION

ID	Technique	Description	Detection in SIEM
T1041	Exfiltration Over C2 Channel	Data exfiltrated over the established C2 channel (HTTP/HTTPS)	Unusual volume of outbound data on existing C2 channel
T1048	Exfiltration Over Alternative Protocol	Data exfiltrated via DNS, ICMP, or custom protocol	Anomalous DNS query volumes, ICMP payload size anomalies
T1567	Exfiltration to Cloud Storage	Data uploaded to Dropbox, OneDrive, Google Drive, Mega	Outbound traffic to cloud storage APIs, large PUT/POST requests
T1052	Exfiltration Over Physical Medium	Data copied to USB drive or external media	Sysmon Event 6 (driver load for USB), Windows Event 6416 (new device)

8 MITRE ATT&CK COVERAGE HEATMAP

This heatmap visualises detection coverage for each mapped technique. Use it to identify gaps in SIEM rules and detection capabilities.

Technique	SIEM Alert	Log Source	EDR Rule	Network Block	Coverage
T1566 Spearphishing	HIGH	HIGH	MED	—	HIGH
T1189 Drive-by	MED	MED	LOW	MED	MED
T1059 PowerShell	HIGH	HIGH	HIGH	—	HIGH
T1047 WMI	MED	MED	MED	—	MED
T1547 Registry Run	HIGH	HIGH	HIGH	—	HIGH
T1053 Sched. Task	HIGH	HIGH	MED	—	HIGH
T1036 Masquerading	MED	MED	HIGH	—	MED
T1055 Proc. Injection	MED	MED	HIGH	—	MED
T1562 Disable Tools	HIGH	HIGH	MED	—	HIGH
T1071 C2 HTTP/DNS	HIGH	HIGH	—	HIGH	HIGH
T1573 Encrypted C2	LOW	MED	—	MED	LOW
T1078 Valid Accounts	MED	HIGH	—	—	MED
T1021 RDP/SMB ★	MED	HIGH	MED	MED	MED
T1550 Pass-the-Hash ★	MED	HIGH	LOW	—	MED
T1057 Discovery ★	LOW	MED	MED	—	LOW
T1041/48 Exfiltration ★	MED	MED	LOW	MED	MED
T1567 Cloud Exfil ★	LOW	LOW	—	MED	LOW

Gap Analysis: Encrypted C2 (T1573), Drive-by (T1189), Discovery (T1057), and Cloud Exfiltration (T1567) show LOW coverage. These are the highest-priority items for the next SIEM tuning cycle. ★ marks techniques added in v2.0.

9

MALWARE TYPE QUICK-REFERENCE CHEAT SHEET

Type	Examples	Spread Vector	Key Indicators	First Response	Sub-playbook
Trojan	Emotet, TrickBot, AgentTesla	Email, malicious download, fake software	Unexpected network connections, keylogger activity, data staging in %TEMP%	Isolate host, capture RAM, block C2 IPs	§4 RAT
Worm	WannaCry, Conficker	SMB, removable drives, email self-replication	High network traffic, SMB errors, multiple hosts infected simultaneously	Isolate entire VLAN, disable SMB if needed, patch immediately	§4 Worm
RAT	DarkComet, NjRAT, AsyncRAT	Phishing, pirated software, drive-by	Persistent outbound connections, webcam/mic activation, remote shell activity	Block C2, disable user account, full forensics	§4 RAT
Spyware	RedLine Stealer, Lumma	Malicious ads, bundled freeware, phishing links	Browser credential theft, clipboard monitoring, keylogging, crypto wallet theft	Collect evidence first, reset ALL credentials, notify affected users	§4 RAT
Ransomware Dropper	Emotet→Ryuk, TrickBot→Conti	Phishing, RDP brute force, supply chain	PowerShell downloads, recon commands before encryption begins	Stop immediately — do NOT wait. Isolate + escalate to Critical	§4 Worm See Ransom PB
Fileless	PowerShell Empire, Cobalt Strike	Office macro, memory injection, LOLBins	No files on disk, lives in memory/registry, uses legitimate tools (PowerShell, WMI)	RAM capture essential. Sysmon + PowerShell logging critical	§4 Fileless
Rootkit	ZeroAccess, Necurs	Trojan dropper, bootkit, kernel exploit	Hidden processes, disabled AV, BSOD on AV scan, boot-time persistence	Offline analysis required. Do NOT trust OS output. Full reimage.	§4 Rootkit

10 IOC COLLECTION & CHAIN OF CUSTODY

★ ENHANCED

10.1 IOC Collection Checklist

IOC Category	Examples	Collection Method	Priority
File-Based	MD5/SHA256 hashes, file names, paths, sizes, compile timestamps	PowerShell Get-FileHash, FTK Imager, EDR	HIGH
Memory-Based	Injected shellcode, suspicious DLLs, network sockets, strings	Volatility 3, Rekall, WinPmem RAM dump	CRITICAL
Network	C2 IPs, malicious domains, ports, contacted URLs, JA3 hashes	SIEM, Firewall logs, Wireshark/PCAP, Zeek	HIGH
Host-Based	Registry keys, scheduled tasks, new services, mutexes, prefetch	Sysmon logs, RegShot, Autoruns, MFT	HIGH
Log-Based	Event IDs: 4688, 4624/25, 7045, 1102, 4698 Sysmon: 1,3,8,11,13	Windows Event Viewer, SIEM, wevtutil export	HIGH
Email	Sender address, attachment hash, subject, email headers, SPF/DKIM results	Email gateway, header analysis tools (MxToolbox)	MED

10.2 Chain of Custody Form ★ NEW

Every piece of evidence MUST be logged in this form immediately upon collection. A copy must be filed with the incident ticket and retained per your evidence retention policy. Evidence integrity is required for insurance claims, law enforcement referrals, and disciplinary proceedings.

Field	Value / Instructions	Completed
Incident ID	IR-YYYY-XXX (from ticketing system)	■
Evidence Item #	Sequential number: EV-001, EV-002, etc.	■
Description	Describe the evidence item (e.g., "RAM dump from HOST-001")	■
Source (Host/Path)	Hostname, IP address, and full file path of origin	■
Collection Timestamp	YYYY-MM-DD HH:MM:SS UTC (must be UTC)	■
Collected By	Full name and role of collecting analyst	■
Collection Method	Tool used (e.g., WinPmem v3, FTK Imager 4.7, wevtutil)	■
SHA-256 Hash (pre-storage)	Hash immediately after collection, before moving the file	■
Storage Location	Path on evidence server / case folder (access-controlled)	■
SHA-256 Hash (post-storage)	Re-hash after copying to evidence store; must match pre-storage hash	■
Write Blocker Used?	YES / NO — if NO, document justification	■
Access Log	List every person who accessed this evidence item, with timestamps	■
Legal Hold Required?	YES / NO — if YES, notify Legal immediately (see §13)	■
Analyst Signature	_____ Date: _____	■
Reviewed By (L2/L3)	_____ Date: _____	■

11 ESCALATION MATRIX

★ ENHANCED

Scenario	Escalate To	Method	Timeframe	SLA Breach Action	Comms Template
Active C2 confirmed	Incident Commander (L3)	Phone + Ticket	Immediately	War Room auto-activated	Template A (\$12)
Malware spreading to multiple hosts	SOC Lead + L3	Phone + Ticket	<15 minutes	CISO notified at 15-min mark	Template A (\$12)
Data exfiltration confirmed	L3 + CISO + Legal	Phone + Email	Immediately	Regulatory clock starts; notify insurers	Template C (\$12)
Critical server infected	L2 + IT Manager	Phone + Ticket	<30 minutes	L3 briefed at 30-min mark	Template B (\$12)
Ransomware dropper identified	L3 + Management	Phone + War Room	Immediately	Switch to Ransomware Playbook	Template A (\$12)
Incident unresolved >4 hours	L3 + CISO	Status Meeting	<4 hours	Executive brief required	Template B (\$12)
★ SLA breached for any severity	On-call Manager	Auto-alert + Phone	At SLA expiry	Log miss; root cause in PIR	N/A
★ Media / press enquiry received	PR/Comms + CISO	Email + Phone	<30 minutes	No technical staff speak to media	Template D (\$12)

12 STAKEHOLDER COMMUNICATION TEMPLATES

★ ENHANCED

Use these pre-approved templates during an active incident. **All external communications (media, customers, regulators) MUST be approved by the CISO or designated management before sending.** Fill in [BRACKETED] fields only — do not rephrase the core language.

Template A — Internal IT / SOC Alert (Critical/High)

Subject: [INCIDENT ID] — Active Security Incident — Action Required

Team,

We are currently responding to a confirmed [SEVERITY] security incident affecting [SYSTEMS/SCOPE].

Current status: [BRIEF STATUS — e.g., "Malware detected on 3 workstations in Finance VLAN; C2 activity confirmed; containment in progress"]

Immediate actions required from IT:

- [ACTION 1 — e.g., "Do not patch or reboot HOST-001, HOST-002, HOST-003 until cleared by IR team"]
- [ACTION 2 — e.g., "Block the following IPs at the perimeter firewall: x.x.x.x, y.y.y.y"]

War Room bridge: [LINK/NUMBER] | Incident channel: [SLACK/TEAMS CHANNEL]

Incident Commander: [NAME] | [PHONE]

Template B — Executive / Management Brief

Subject: [INCIDENT ID] — Security Incident Executive Brief — [DATE]

Incident Summary: A [malware type, if known] security incident was detected on [DATE/TIME]. [X] systems are currently affected.

Business Impact: [CURRENT IMPACT — e.g., "Finance team unable to access shared drives; customer portal operational"]

Response Status: Incident Response Team is actively investigating. Containment actions have been taken.

Estimated Resolution: [TIME ESTIMATE or "Under investigation — next update in 2 hours"]

Decision Required: [IF ANY — e.g., "Approval to take production server offline for imaging"]

Next update: [TIME] | Contact: [INCIDENT COMMANDER NAME/PHONE]

Template C — Data Breach / Exfiltration Notification (Legal Review Required)

■ THIS TEMPLATE REQUIRES LEGAL REVIEW BEFORE SENDING

Subject: Potential Data Security Incident Notification — [ORGANISATION NAME]

We are writing to inform you that we have identified a potential security incident that may have involved [DESCRIPTION OF DATA — e.g., "access to customer account information"].

What happened: On approximately [DATE], we detected [BRIEF DESCRIPTION] affecting [SCOPE].

What information may be involved: [DATA TYPES — e.g., names, email addresses, account numbers].

What we are doing: We immediately [CONTAINMENT ACTIONS TAKEN]. We have engaged cybersecurity specialists and are conducting a full investigation.

What you can do: [RECOMMENDED ACTIONS FOR AFFECTED PARTIES]

For questions: [DEDICATED INCIDENT CONTACT / HOTLINE]

Template D — Media / Press Holding Statement (PR Approval Required)

■ DO NOT DISTRIBUTE WITHOUT PR + CISO APPROVAL

"We are aware of a cybersecurity incident and are taking it very seriously.

Our security team responded immediately and is working to investigate and address the situation.

We are committed to protecting the data and systems entrusted to us.

We will provide further information as our investigation progresses.

We are unable to comment further at this time."

Do NOT:

- Confirm or deny specific systems, data, or attacker identity to media
- Allow technical staff to speak with journalists
- Post on social media about the incident without PR approval

13 LEGAL & REGULATORY ANNEX

★ ENHANCED

Disclaimer: This annex provides general guidance only. Always consult your Legal and Compliance team for jurisdiction-specific obligations. Regulatory requirements are subject to change.

13.1 Regulatory Notification Requirements

Regulation	Scope	Notification Deadline	Notify	Trigger
GDPR	EU personal data of EU residents	72 hours of awareness	Supervisory Authority (e.g., ICO, CNIL)	Any breach likely to result in risk to individuals
HIPAA	US healthcare — PHI	60 days of discovery	HHS + affected individuals	>500 individuals affected in a state
PCI DSS	Payment card data	Immediately (24-72hr)	Card brands + acquiring bank	Any confirmed or suspected card data compromise
NIS2 (EU)	Critical infrastructure / essential services	24hr early warning; 72hr report	National CSIRT	Significant incidents affecting services
DORA (EU Finance)	EU financial entities	4hr initial; 72hr intermediate	National Competent Authority	Major ICT-related incidents
State laws (US)	Varies by state	30-90 days (varies)	State AG + affected individuals	PII of state residents affected

13.2 Law Enforcement Engagement

- **When to engage:** Nation-state suspected, critical infrastructure affected, financial crime, extortion demands, or when evidence suggests criminal activity.
- **Who to contact:** FBI (US) — IC3.gov | CISA — cisa.gov/report | Europol (EU) — EC3 | National CERT/CSIRT
- **Before engaging:** Notify CISO + Legal. Do not unilaterally contact law enforcement during an active incident.
- **Evidence preservation:** Do not destroy, alter, or allow evidence to decay before law enforcement review. Issue a legal hold notice to IT and relevant staff.
- **Information sharing:** Law enforcement may request copies of logs, malware samples, and IOCs. Only provide with Legal approval and under a formal evidence transfer agreement.

13.3 Legal Hold Procedure

A legal hold must be issued when there is a reasonable anticipation of litigation, regulatory investigation, or law enforcement involvement.

Step	Action	Owner
1	Notify Legal immediately upon suspicion of criminal activity or regulatory breach	Incident Commander
2	Legal issues written legal hold notice to IT, HR, and all personnel who may have relevant data	Legal
3	Suspend routine data deletion/rotation for all systems within scope of the incident	IT / Sysadmin
4	Preserve all evidence per chain of custody (§10). Do not alter original evidence.	IR Team
5	Document all access to preserved evidence in the Chain of Custody log	IR Team
6	Legal confirms scope and lifts hold when matter is resolved	Legal

13.4 Cyber Insurance Notification

- Notify your cyber insurer as soon as a significant incident is confirmed — most policies require notification within 24-72 hours.
- Do NOT undertake major remediation activities that destroy evidence before notifying the insurer — this may void coverage.
- The insurer may assign their own IR firm. Coordinate with the CISO before accepting external IR resources.
- Document all incident-related costs from the outset: staff time, tool costs, external consultants, legal fees, business interruption.

14 TOOLS REFERENCE

Tool	Phase	Purpose	Notes
SIEM	All phases	Central log aggregation, correlation, alerting	Primary detection and investigation platform
EDR Platform	All phases	Endpoint telemetry, process isolation, remote triage	Use for host isolation (preferred over network block)
Firewall / NGFW	Containment	Network isolation, IP/domain blocking, VLAN quarantine	IPS + App Control enabled
Sysinternals Suite	ID, Eradication	Process Explorer, Autoruns, TCPView, ProcMon, PsExec	Free — Microsoft (see §6 for commands)
Volatility 3	Identification	Memory forensics — processes, network connections, injected code	Open Source — Python. See §4 Fileless sub-playbook
WinPmem / LiME	Identification	RAM acquisition for Windows (WinPmem) and Linux (LiME)	Must be pre-staged on IR jump box
VirusTotal / Any.run	Identification	Submit file hashes or live sandbox malware analysis	Web-based. Do NOT submit sensitive files to public VT.
Sysmon	Identification	Enhanced Windows event logging — process, network, registry	Use SwiftOnSecurity config. Deploy via GPO.
Wireshark / Zeek	Analysis	PCAP capture and analysis, JA3 fingerprinting, C2 traffic analysis	Zeek for continuous capture; Wireshark for manual analysis
MITRE ATT&CK; Navigator	All phases	Map TTPs, visualise coverage gaps, track attack progression	Free — attack.mitre.org
FTK Imager	Identification	Forensic disk imaging with hash verification	Free tier available. Required for chain of custody.
AlienVault OTX / MISP	Analysis	Threat intelligence sharing, IOC correlation	Integrate with SIEM for automated IOC matching

15 POST-INCIDENT METRICS & KPIS

★ ENHANCED

Track these metrics for every incident and report monthly to CISO and management. Use the dashboard to identify trends, SLA compliance issues, and areas for improvement.

KPI	Definition	Target	Measurement Method
MTTD (Mean Time to Detect)	Time from malware first active on host to first alert fired	<2 hours	Alert timestamp minus earliest artefact timestamp in logs
MTTA (Mean Time to Acknowledge)	Time from alert to analyst beginning investigation	<15 min (Critical) <30 min (High)	Ticket acknowledgement timestamp minus alert creation
MTTR (Mean Time to Respond)	Time from alert to full containment of the threat	<4 hours (Critical) <8 hours (High)	Containment confirmation timestamp minus alert creation
MTTRC (Mean Time to Recover)	Time from containment to full business service restoration	<24 hours	Service restored timestamp minus containment confirmation
SLA Compliance Rate	Percentage of incidents meeting their severity-specific SLA	>95%	(Incidents meeting SLA / Total incidents) × 100
False Positive Rate	Percentage of alerts that were false positives	<15%	(FP alerts / Total alerts) × 100 — review monthly
Reinfection Rate	Percentage of remediated hosts re-infected within 30 days	<2%	Track via EDR telemetry on remediated hosts
Escalation Accuracy	Percentage of escalations that were correctly severity-classified	>90%	PIR review — was initial severity correct vs final classification?
IOC-to-Block Time	Time from IOC identification to block applied at firewall/DNS	<30 min (Critical)	Block rule timestamp minus IOC identification in ticket

Reporting cadence: MTTD / MTTR / SLA Compliance reported weekly to SOC Lead. Monthly trend report to CISO. Quarterly executive dashboard update to Board/Management.

16 REFERENCES & FURTHER READING

16.1 Standards & Frameworks

- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>
- MITRE ATT&CK; Enterprise Matrix v14: <https://attack.mitre.org/matrices/enterprise/>
- SANS Incident Handler's Handbook: <https://www.sans.org/white-papers/33901/>
- CISA Incident Response Guidance: <https://www.cisa.gov/resources-tools/resources>
- NIS2 Directive (EU): <https://digital-strategy.ec.europa.eu/en/policies/nis2-directive>
- DORA Regulation (EU): https://www.eiopa.europa.eu/digital-operational-resilience-act-dora_en

16.2 Tools Documentation

- Volatility 3 Documentation: <https://volatility3.readthedocs.io>
- Sysmon Configuration (SwiftOnSecurity): <https://github.com/SwiftOnSecurity/sysmon-config>
- MITRE ATT&CK; Navigator: <https://mitre-attack.github.io/attack-navigator/>
- Any.run Interactive Sandbox: <https://any.run/>
- AlienVault OTX Threat Intelligence: <https://otx.alienvault.com/>
- Sysinternals Suite: <https://learn.microsoft.com/en-us/sysinternals/>

16.3 Malware Intelligence Resources

- MalwareBazaar (Abuse.ch): <https://bazaar.abuse.ch/>
- VirusTotal Intelligence: <https://virustotal.com/>
- Hybrid Analysis: <https://hybrid-analysis.com/>
- Malpedia Malware Encyclopedia: <https://malpedia.caad.fkie.fraunhofer.de/>
- MISP Threat Intelligence Sharing: <https://www.misp-project.org/>

17 APPENDIX — ENHANCED INCIDENT REPORT TEMPLATE

Complete this report within 5 business days of incident closure. Submit to CISO, SOC Lead, and relevant stakeholders.

Field	Value
Incident ID	IR-YYYY-XXX
Incident Title	Malware Infection — [System/User Name]
Severity	Critical / High / Medium / Low
Date/Time Detected (UTC)	YYYY-MM-DD HH:MM
Date/Time Contained (UTC)	YYYY-MM-DD HH:MM
Date/Time Resolved (UTC)	YYYY-MM-DD HH:MM
MTTD	___ hours ___ minutes
MTTR	___ hours ___ minutes
SLA Met?	YES / NO — if NO, document reason
Affected Systems	List of hostnames / IPs
Malware Family / Type	e.g., Emotet, AsyncRAT, Fileless PowerShell
Sub-Playbook Used	\$4 — [Type]
Initial Vector	Email / Web / USB / RDP / Other
MITRE Tactics Observed	e.g., Initial Access, Execution, Persistence, Lateral Movement, C2, Exfiltration
IOC Summary	File hashes, C2 IPs/domains, persistence keys — attach full IOC list
Containment Actions	Description of actions taken
Eradication Actions	Description of removal steps
Data Exfiltrated?	Yes / No / Unknown — details if Yes; regulatory notification required?
Root Cause	Technical root cause summary
Chain of Custody	Evidence items collected (reference §10 CoC forms): EV-001, EV-002...
Legal / Regulatory Actions	Notifications sent, law enforcement engaged, legal hold issued?
Lessons Learned	Key findings and gaps identified
Recommendations	Actions to prevent recurrence — assign owner and due date
Detection Rules Updated?	YES / NO — list rule IDs updated
Playbook Updated?	YES / NO — version bump if updated
Analyst Name	Name / Contact
Reviewed By	Incident Commander / SOC Lead
CISO Sign-off	_____ Date: _____